



AI 에이전트 시대, 보안 경계는 어디까지인가?

SASE가 놓치는 리스크와 새로운 대응 전략



윤재탁
Specialist Solutions Engineer
Cloudflare

나의 AI 사용기 - AI 어디까지 써보셨나요

호기심에



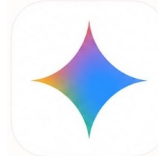
AI 스피커

써보라고 해서



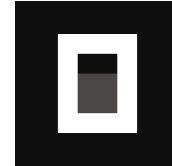
대화형 AI

정리 및 분석



AI 비서

없으면 일 못함



AI 에이전트

AI 도입을 고민하던 시대는 끝났습니다



AI의 발전 방향을 알아보겠습니다

단계	AI의 역할	회사 관점에서 통제 질문
대화형 AI (Chat AI)	정보 조회 및 질문 답변 예> "우리 회사 연차 휴가 신청 규정이 어떻게 돼?"	누가 어떤 AI에 접근할 수 있는가?
AI 비서 (AI Assistant)	문서 작성, 요약 및 단순 분석 예> "이 신규 프로젝트 제안서 요약하고, 관련 보고서 초안 좀 작성해줘."	어떤 데이터를 보여줄 것인가?
AI 에이전트 (AI Agent)	다양한 도구 연동 및 프로세스 수행 예> "최근 3개월간 공급업체 세금계산서 조회하고, 예산 규정 확인한 뒤 지출결의서 초안 작성해서 팀장님께 결재 올려줘."	어떤 권한을 부여할 것인가?
자율형 AI (Autonomous AI)	자체 판단 및 독자적 의사결정 예> "설정해둔 재고 기준에 따라 부족한 부품이 있으면 자동으로 최저가 입찰을 진행하고, 주문서발주까지 처리한 뒤 결과만 보고해줘."	어떤 기준으로 관리하고 책임질 것인가?

브라우저를 기반으로 AI 사용하고 있어요



[접근 제어]

- 신원 확인
- 기기 상태
- 네트워크

[AI 식별]

- 승인
- 미승인
- 보류

[테넌트 식별]

- 회사 계정
- 개인 계정

[행위 제어]

- 업로드
- 다운로드

[컨텐츠 제어]

- 개인 정보
- 민감 정보
- 파일 유형

[로깅]

- 프롬프트
- 페이로드

브라우저만 사용하는 것이 아니더라도



[테넌트 식별의 어려움]

- 회사와 개인 API Key가 모두 같은 엔드포인트(예> api.anthropic.com)
- 유출/공유된 API Key



[행위 제어의 어려움]

- 각 행위에 대한 동일한 API 요청(예> POST /v1/messages)



[컨텐츠 제어의 어려움]

- JSON 문자열/Base64가 포함된 파일



[로그 및 관리의 어려움]

- 토큰 사용량과 비용
- 하나의 프롬프트가 여러 HTTP 요청으로 분리

ChatAI와 AI Agent는 서로 다릅니다

구분	Chat AI 예> ChatGPT / Claude	AI Agent 예> Codex / Claude Code
중심 기능	대화·질의응답	목표의 자율 수행
컨텍스트 활용	Prompt·첨부파일	파일·시스템·외부 서비스
Tool 사용	없거나 제한적	다수 Tool을 연속 사용
시스템 변경	일반적으로 없음	정책 범위에서 자율 실행 가능
주요 보안 질문	• 누가 AI를 사용했는가? • 승인된 AI인가? • 기업 계정인가? • 어떤 Prompt와 파일을 전송했는가? 사용자가 입력하거나 업로드하는 정보의 유출 → SWG·DLP·CASB 중심의 접근 및 콘텐츠 통제가 효과적	• 어떤 Agent가 어떤 모델을 호출했는가? • 어떤 system/user prompt가 전달됐는가? • 어떤 파일·로그·소스코드가 context에 포함됐는가? • 어떤 tool이 호출됐는가? 다양한 도구(로컬 파일, API, MCP 등)를 사용하여 실제 행위를 수행 → HTTP 트래픽 통제만으로는 불충분

AI Gateway 도입이 필요하지 않을까요



[계정 관리]

- 개인 계정이나 개인 키 대신, 회사가 발급한 승인된 토크로만 AI를 사용하도록 통합

[사용 통제]

- 허용된 AI 모델과 허용된 질문만 사용하도록 제한하고, 과도한 사용을 자동으로 차단

[정보 보호]

- AI에 보내는 내용과 AI가 돌려주는 답변에서 개인정보와 기밀정보, 위험한 내용을 검사

[사용 기록]

- 누가, 어떤 업무로, 어떤 AI를, 얼마나 사용했는지 기록하고 조회

[비용 관리]

- 부서와 사용자별로 사용량과 예산 한도를 정하고, 반복되는 요청은 재사용해 비용 절감

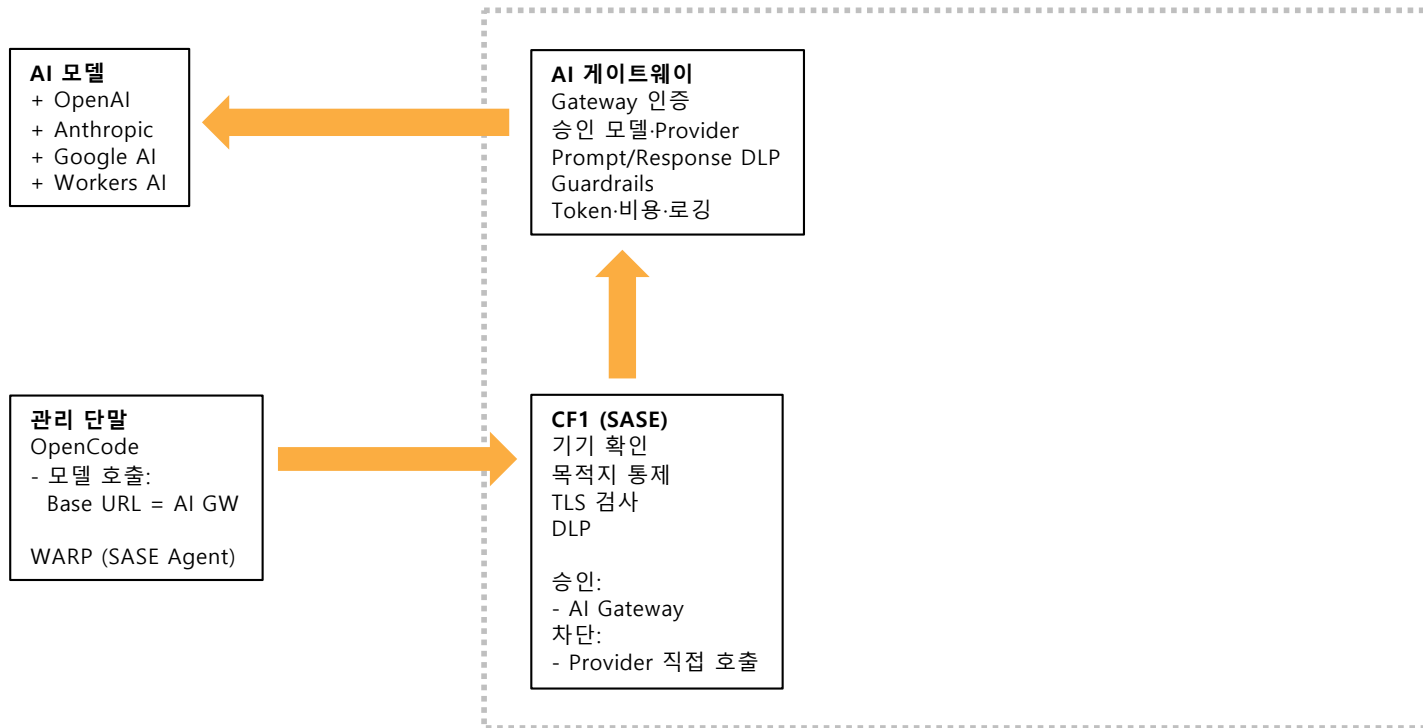
AI Gateway로 무엇을 할 수 있나요

요구 사항	설명	기능 (Cloudflare 기준)
승인된 통로	회사가 정한 하나의 통로로만 AI를 사용함	Authenticated Gateway
회사 키 중앙 보관	통로가 회사 키를 대신 보관하므로 개인 키가 불필요	BYOK
허용된 AI만 사용	통로를 지날 때 업무에 승인된 AI만 연결됨	Models, Dynamic Routing
위험한 질문·답변 차단	오가는 내용 중 위험하거나 부적절한 것은 걸러짐	Guardrails
민감정보 검사	개인정보와 기밀정보가 새어 나가지 않는지 함께 검사함	DLP
과도한 사용 제한	한 사람이나 한 프로그램이 지나치게 많이 사용하지 못하게 함	Rate Limiting
예산 한도	정해진 예산을 넘으면 사용을 멈춤	Spend Limits
사용 기록	모든 이용 내역이 기록으로 남음	Logging, Analytics
업무·사용자 구분	누가 어떤 업무로 사용했는지 구분해 보여줌	Custom Metadata
기존 모니터링 연계	이 기록은 회사가 이미 쓰는 모니터링 체계로 전달됨	OpenTelemetry, Logpush
반복 요청 재사용	같은 요청은 다시 계산하지 않고 재사용해 비용을 줄임	Caching
장애 대응	AI 서비스에 문제가 생겨도 자동으로 대응해 업무가 이어짐	Fallbacks, Request Retry

SASE와 AI Gateway는 대체 관계가 아닌 상호 보완 관계입니다



AI Gateway 활용 방안을 공유합니다



내부에서 MCP를 사용하는 것 같더라구요

커넥터

전체 연결됨 연결되지 않음

커넥터

유형

상태

GitHub 연동

웹

✓

Notion

웹

✓

추가

앞서 설명한 내용을 요약해서 노선에 'MCP 학습'이라는 페이지를 새로 생성해서 옮겨줘

마크다운으로 MCP 학습 페이지 구성했습니다

'MCP 학습' 페이지를 만들었습니다 → MCP 학습

항목	Web 예> Claude에서 Connector 메뉴	CLI 예> Claude Code에서 claude mcp add 명령어
연결 주체	해당 LLM (Anthropic에서 MCP 서버 직접 연결)	사용자 단말 (Claude Code가 MCP 서버 직접 연결)
SASE 가시성	SWG 및 DLP 적용 불가	SWG 및 DLP 적용 가능
보안 고려사항	MCP 사용은 Web 커넥터 사용을 제한하고 CLI와 MCP Portal로 유도하는 것이 유리	

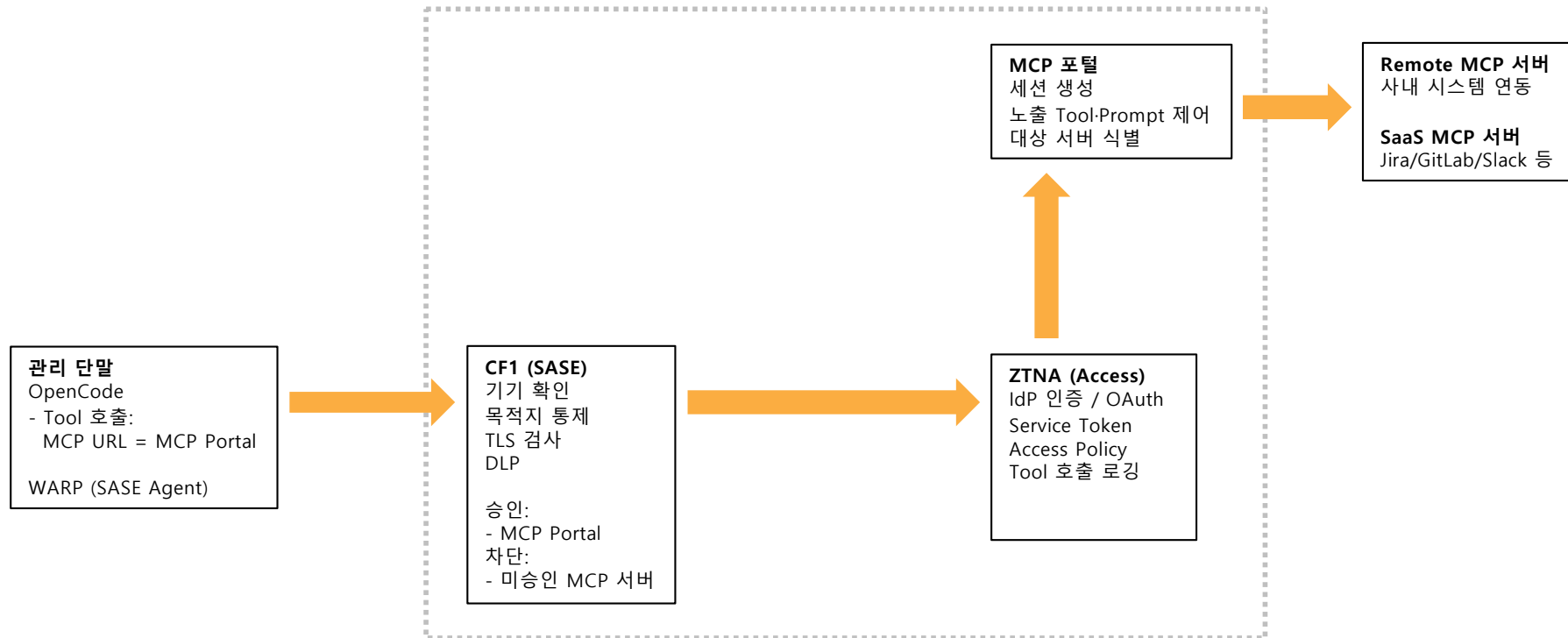
AI Gateway와 MCP Portal을 비교해 볼까요

구분	AI Gateway	MCP Portal
통제 대상	AI 모델 호출	AI가 사용하는 도구
핵심 질문	어떤 AI에 무엇을 보냈는가	어떤 도구로 무엇을 했는가
신원 확인	발급된 토큰	회사 계정 로그인
주요 통제	모델, 프롬프트, 사용량, 비용	서버, 도구, 접근 범위, 자격
요약	AI를 쓰는 통로	AI가 일하는 통로

MCP Portal로 무엇을 할 수 있나요

요구 사항	설명	기능 (Cloudflare 기준)
승인된 통로	여러 도구 서버를 하나의 주소로 모아 그 통로로만 연결함	MCP Server Portal
신원 확인	회사 계정으로 로그인한 사용자만 연결할 수 있음	Cloudflare Access, Managed OAuth
사람 없는 연결	자동화나 서버간 연결도 승인된 자격으로만 허용함	Service Token
사용자별 접근 범위	사용자와 부서에 따라 사용할 수 있는 서버가 달라짐	Access Policy
허용된 기능만 노출	업무에 필요한 도구만 골라서 보여줌	Tool-Prompt 노출 설정, Allowlist
이름 정리	헷갈리는 도구 이름과 설명을 회사 용어로 정리함	Aliases, Namespacing
자격 중앙 보관	사용자가 각 서비스의 키를 직접 다루지 않음	상위 OAuth 관리, Admin Credential
사용 기록	누가 어떤 도구를 호출했는지 기록으로 남음	Access Logs
내용 검사	도구로 오가는 내용에 민감정보가 있는지 검사함	Gateway Routing + DLP
출발지 고정	회사가 허용한 IP로만 상위 서버에 접속함	Egress Policy
불필요한 정보 축소	AI에 전달되는 도구 설명을 줄여 정확도와 비용을 개선함	Context Optimization, Code Mode
연결 관리	필요한 서버만 켜서 쓰고 오래 쓰지 않으면 자동 종료됨	Session 관리

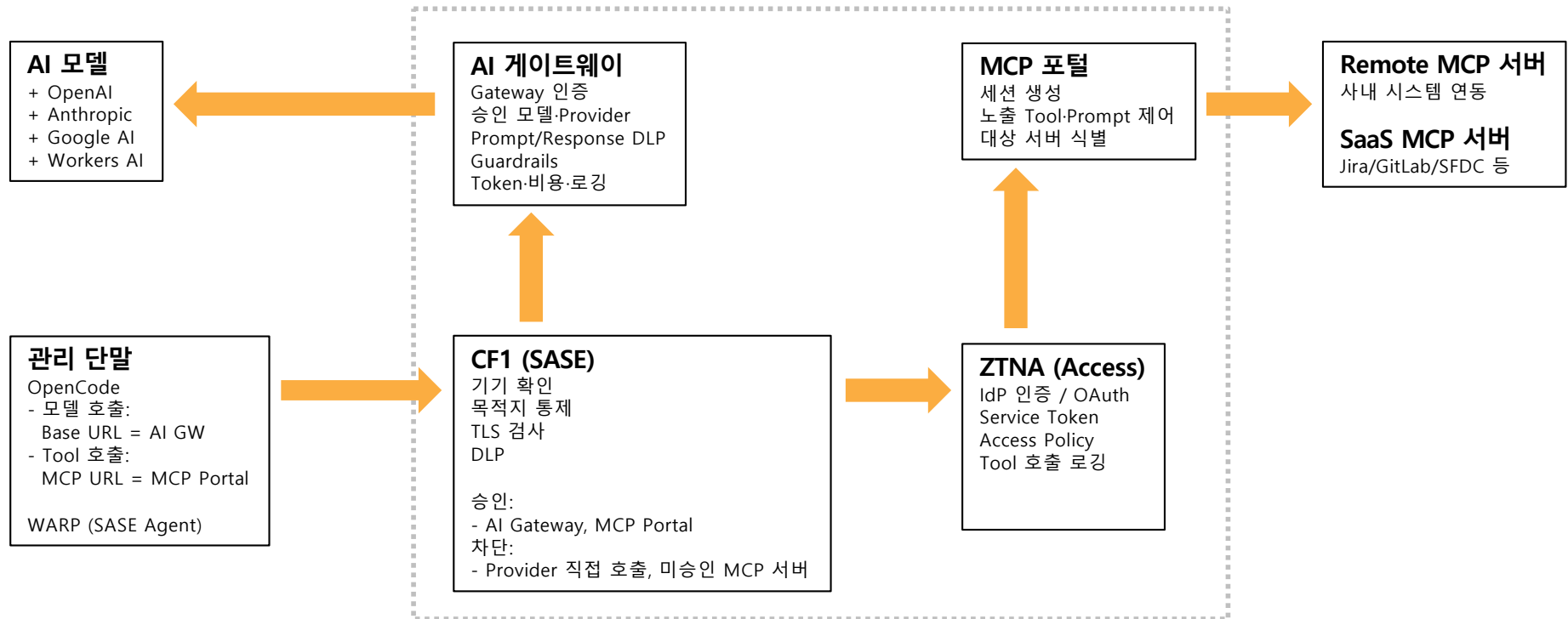
MCP Portal 활용 방안을 공유합니다



AI 거버넌스가 필요한 시기입니다

AI Agent 시대의 서로 다른 통제 대상	
기존	AI Agent 시대
• 사람 - 누가 접근하는가? • 애플리케이션 - 어떤 앱을 사용하는가? • 네트워크 - 어디서 접속하는가? • 데이터 - 무엇을 볼 수 있는가?	• AI 모델 - 어떤 모델을 허용할 것인가? • 프롬프트 - 어떤 지시와 데이터가 입력되는가? • 데이터 접근 - AI가 어떤 데이터를 조회하는가? • 도구 사용 - 어떤 Tool/API를 실행하는가? • 업무 실행 - 조회만 가능한가, 실행도 가능한가? • 결과물 - 생성 결과를 어떻게 검토하고 사용할 것인가?

Cloudflare는 이렇게 사용하고 있어요



AI 도입보다 AI 관리 체계를 먼저 준비해야 합니다

- ☐ **AI 사용 현황:** 우리 조직은 어떤 AI를, 누가, 어떤 업무에 사용하고 있는가?
- ☐ **AI 사용 정책:** 허용되는 AI와 금지되는 AI는 무엇인가?
- ☐ **데이터 정책:** AI에 입력 가능한 데이터와 금지되는 데이터는 무엇인가?
- ☐ **Agent 정책:** AI Agent가 수행할 수 있는 업무 범위는 어디까지인가?
- ☐ **MCP / Tool 정책:** Agent가 접근 가능한 시스템과 도구는 무엇인가?
- ☐ **권한 정책:** Agent는 누구의 권한으로 행동하며, 최소 권한 원칙이 적용되는가?
- ☐ **승인 정책:** 메일 발송, 고객 안내, 심사 처리 등 어떤 실행은 사람 승인이 필요한가?
- ☐ **감사 정책:** 프롬프트, 데이터 접근, Tool 호출, 실행 결과가 기록되는가?

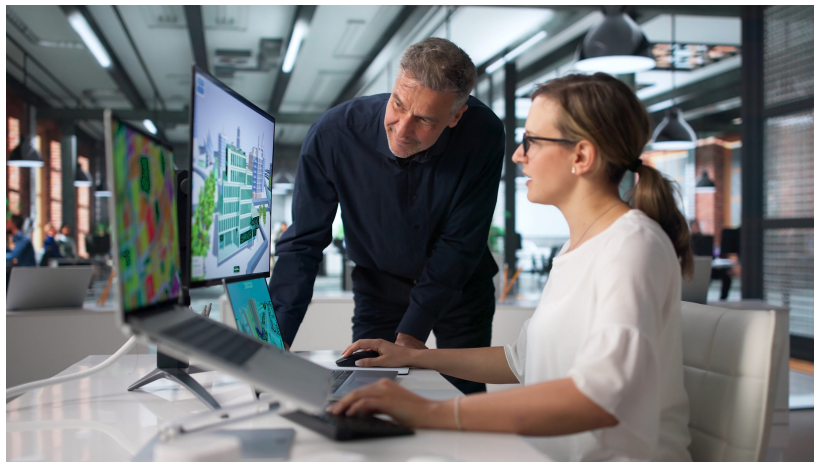
AI는 새로운 애플리케이션이 아닌 새로운 직원입니다

왜 AI를 '직원'으로 보아야 하는가?

우리는 새로운 도구를 구매하는 것이 아닙니다.

자율적으로 판단하고 데이터를 학습하며 고유한 지적 산출물을 만들어내는 **디지털 구성원**을 맞이하는 것입니다.

AI의 도입은 단순 설치(Install)가 아닌 **채용(Hiring)**과 같은 관점으로 접근해야 리스크를 최소화하고 성과를 극대화할 수 있습니다.



직원을 채용하면

- 1) 신원을 확인하고
- 2) 권한을 부여하고
- 3) 업무 범위를 지정하고
- 4) 행동을 기록하고
- 5) 결과를 감사합니다

AI도 동일해야 합니다.

감사합니다

→ 1 888 99 FLARE

✉ enterprise@cloudflare.com

🌐 cloudflare.com